

Pautas para el Personal Seguridad de la Información



Diseño del Sistema de Resiliencia y Ajuste con los Estándares

Este sistema de resiliencia lo diseñó la Corporación Risk and Strategic Management (RSM), una compañía especialista en el diseño y la implementación de estrategias complejas de resiliencia que protegen a las personas, las instalaciones, los bienes, la información, las operaciones y la reputación organizacional. Este sistema se encuentra en conformidad con las siguientes normas de la ISO y la BSI para garantizar que refleja las normas y prácticas profesionales de las Organizaciones de Alta Confiabilidad: ISO 31000: Gestión del Riesgo; ISO 22317: Análisis de impacto comercial; ISO 22301: Gestión de la continuidad de negocio; ISO 22320: Gestión de Emergencias; ISO 34001: Seguridad y resiliencia; ISO 22316: Resiliencia organizacional y BSI 17091: Gestión de crisis.

¿Por qué es importante la seguridad de la información?

Una efectiva seguridad de la información previene la pérdida o el robo de datos y garantiza que no haya información desprotegida, sin importar lo sensible que sea dicha información. Cualquier tipo de información que criminales, gobiernos hostiles, prensa, militantes o terroristas puedan usar para perjudicar o avergonzar a los individuos, a la organización o a los grupos de interés, debe considerarse como sensible y debe protegerse de manera adecuada.

Algunos ejemplos específicos de información sensible son:

- Información financiera o de contratos
- Planes e informes operativos
- Estrategias organizacionales
- Información sobre grupos de interés externos
- Propuestas de negocios
- Visitas y actividades de VIP
- Propiedad intelectual
- Registros y agenda de viajes
- Biodatos del personal y registros de sus familiares
- Informes disciplinarios o promocionales
- Informes o políticas sobre crisis e incidentes
- Documentos de coberturas de seguro
- Paquetes de compensación
- Reuniones y eventos con clientes
- Investigaciones
- Planes y políticas de seguridad

Entre los riesgos de una seguridad de la información deficiente se incluyen:

- Robos, asaltos y hurtos
- Ataques que resultan en lesiones o muerte
- Secuestro y toma de rehenes
- Ataques armados
- Atención negativa de la prensa
- Pérdida de ventajas competitivas y negocios
- Humillación a individuos o la organización
- Riesgos reputacionales y legales
- Daños a la moral de los empleados
- Perjuicios a los grupos de interés externos

Sus Responsabilidades...

Una seguridad de la información sólida puede reducir considerablemente las probabilidades de que su organización sea el blanco de individuos o grupos hostiles, lo que ayuda a proteger a las personas, la información, las operaciones y los intereses de negocios. No obedecer estas medidas resultará inevitablemente en violaciones de seguridad. La seguridad de la información consiste en:

- Limitar el acceso a sus datos, por medio de capas de encriptado y protocolos de seguridad
- Proteger los instrumentos físicos de almacenamiento de datos o material impreso de la información
- Reducir las vulnerabilidades que puedan facilitar la pérdida o el robo de datos
- Reportar las violaciones de seguridad de inmediato
- Prestar atención a su entorno y a lugares donde otras personas puedan escuchar sus conversaciones.

Protocolos de Seguridad de Datos

A continuación se describen algunas áreas donde usted es responsable por la seguridad de la información:

- 1. Política de Escritorio Limpio:** La información sensible debe protegerse bajo cerradura cuando no se encuentre en uso, especialmente durante el horario nocturno, que es cuando el personal de limpieza puede tener acceso libre a todas las instalaciones. Deben proporcionárseles gabinetes o habitaciones con cerraduras al personal que use información sensible, para la protección de la misma.
- 2. Viajar con Información:** Las personas que viajen deben tomar en cuenta la información que requieren para dicho viaje y si la pérdida de cualquier información puede comprometer a individuos, la organización u otros grupos de interés. Si la probabilidad de pérdida o robo es demasiado grande, los empleados deben solicitar una laptop desinfectada. Solo debe llevarse información esencial, por lo general en una memoria USB o disco duro externo que estén encriptados.
- 3. Robo de Datos:** Si una persona sufre una pérdida de datos o es víctima de un robo, debe inmediatamente reportar el incidente a un gerente y proporcionar una lista completa de la información robada, a fin de realizar una Evaluación del Riesgo sobre las posibles repercusiones de la pérdida. Un gerente adecuado debe notificar a las partes afectadas, entre las que se incluyen los grupos de interés externos, destinatarios de la oficina, socios, implementadores y subcontratistas. Puede que sea necesario notificar a las agencias gubernamentales o a la policía. Se aplicarán las mismas consideraciones si se cree que la información se encuentra comprometida.

4. **Eliminar Información:** El departamento de Tecnología de Información es responsable de la eliminación al momento de desechar computadoras, discos duros, memorias USB o equipo de red.
5. **Eliminación de datos cuantitativos:** Los archivos y documentos que contengan información cuantitativa deben destruirse de una manera que proteja la integridad de dicha información. Esto puede ser por medio de una trituradora de papel, o en caso de no contar con una, puede procederse a quemar el documento.
6. **Contraseñas:** Cree contraseñas largas (con un mínimo de 8 caracteres) con números, letras mayúsculas, minúsculas y símbolos. Un buen ejemplo de una contraseña es: *lI0veMyMutæø5934*. Un mal ejemplo de una contraseña es: *JohnDoe*. **NO** use ninguna contraseña relacionada con información personal, tales como su número de seguridad social, su fecha de nacimiento, el nombre de sus hijos, el segundo nombre de su pareja. En lugar de esto, cree una contraseña aleatoria con números, letras, símbolos (de estar permitido), y tanto letras mayúsculas como minúsculas. Intente crear una contraseña que pueda recordar sin necesidad de escribirla, pero que sea lo más aleatoria posible. Si necesita escribir una contraseña, llévela en un lugar seguro como su billetera. **NO** lleve su contraseña junto con su computador.
7. **Virus/spyware/cookies de seguimiento:** Al usar el internet, especialmente si descarga algo de un servidor público, acumulará spyware y cookies de seguimiento. Estas pueden removerse con un removedor de spyware/cookies de seguimiento. Los virus, gusanos y troyanos son más difíciles de remover. Puede evitar estos de la siguiente manera:
- **NO** abra documentos adjuntos o links en un email a menos que verifique quién los envió.
 - **NO** desactive su firewall. Ajuste el nivel de seguridad de esta al máximo.
 - **NO** desactive el bloqueador de ventanas emergentes de su navegador.
 - **NO** descargue archivos torrent o provenientes de páginas P2P. Contacte al departamento de Tecnología de Información si sospecha que una página puede ser fraudulenta.
 - **NO** deje contraseñas a la vista, o a su computadora desbloqueada/desatendida en un área pública.
 - **NO** comparta información personal u organizacional con una persona a quien no conoce o en la que no confía. De ser posible, verifique la identidad de estos con una tercera parte confiable antes de entrar en contacto con desconocidos.

Robo de Datos: Sea extremadamente cuidadoso con su computadora al viajar a lugares públicos y/o peligrosos. Peligroso puede definirse como cualquier lugar donde sus materiales o hardware sensibles están en peligro de robo, daño o uso indebido.

- Siempre tenga su computadora en un lugar seguro. De ser posible, guárdela bajo cerradura para prevenir robos. Si se queda en una habitación de hotel con una caja fuerte, úsela para guardar su computadora y todo material sensible al salir de su habitación.
- Guarde todos sus archivos en una carpeta compartida para garantizar que es respaldada cada vez que se conecte al internet.
- Si debe dejar una laptop dentro de un vehículo, déjela en el maletero, no en la parte principal del vehículo donde puede atraer la atención de criminales.

Protocolos de Gestión de Seguridad Individual

Proteger la información puede estar relacionado con lo que dice y hace al viajar, socializar o trabajar. Es muy importante tener consciencia situacional de sus alrededores y de lo que usted y otros dicen y hacen. Algunas reglas importantes sobre seguridad de la información son:

- **Fotos y Videos:** No tome o envíe fotografías o videos de áreas, personas o actividades sensibles, a menos que se le haya autorizado. Esto podría proporcionar información comprometedoras que puede usarse para perjudicar a personas, bienes y operaciones. También puede usarse con el objetivo de avergonzar considerablemente a alguien, especialmente si es compartida con la prensa. Si tiene permitido tomar fotos y videos, no debe compartirlos hasta la conclusión de las actividades.
- **Correos electrónicos y mensajes de texto:** De por sentado que los correos y mensajes de texto que se envían afuera de la organización no están protegidos. Grupos hostiles pueden fácilmente interceptarlos, o el propio remitente puede compartirlos con un grupo más amplio sin darse cuenta.
- **Redes Sociales:** No debe publicar imágenes, información, comentarios o cualquier otro tipo de archivos relacionados con la organización sin autorización previa. Estos son medios públicos para compartir información, por lo que la información que publique será rápidamente compartida con un grupo mucho más amplio del esperado. Nunca publique información sensible sobre una actividad antes de que esta tenga lugar. Esto podría darle tiempo a grupos hostiles para planificar y llevar a cabo sus objetivos, ya que les proporcionó la información necesaria para lograrlo. Debe dar por sentado que cualquier persona puede acceder a su información en las redes sociales.

- **Conversaciones y Llamadas Telefónicas:** Debe estar siempre atento a sus alrededores y dar por sentado que es posible que otros estén escuchando sus conversaciones o llamadas telefónicas. Por lo general las personas olvidan quiénes están cerca de ellos o la distancia de propagación del sonido, por lo que usted u otros terminan divulgando información sensible sin darse cuenta. Es recomendable encontrar un área privada o apartada para tener sus discusiones o llamadas. También debe tener en cuenta que algunas áreas, como salas de conferencias o habitaciones de hotel, pueden estar monitoreadas con dispositivos electrónicos de escucha.
- **Compartir Información con Amigos y Familiares:** Debe saber que aunque puede confiar en sus familiares y amigos, las personas tienden a contar chismes, y existe un riesgo verdadero de que puedan hablar con otros sobre sus actividades, sin querer perjudicarlo a usted. Es posible que también envíen correos electrónicos, compartan fotos o documentos, o que alguien pueda escucharlos, lo que lo comprometería a usted y a los demás. Por lo tanto, debe ser selectivo con lo que comparte y advertirle a estas personas sobre las medidas de seguridad de la información.
- **Leer Informes y Documentos:** Por lo general a las personas les gusta leer documentos o informes en sus laptops o en formato físico como fotocopias. Usualmente no están conscientes de que otros pueden leer esa información, especialmente durante vuelos o viajes en tren, donde hay mucha gente cerca. Debe tomarse cuidado para garantizar que otras personas no puedan leer la información “por encima de su hombro”. Pueden usarse protectores de pantalla en las laptops para reducir el riesgo.

Otras Instrucciones